

ICT Technical Review & Compliance Checklist

Audit Tool for Dirt Trails Safaris Platform

Executive Summary: This technical review and compliance checklist has been constructed to evaluate the legal, security, and operational readiness of the integrated digital tourism platform under Uganda's regulatory jurisprudence. Aligned with the Digital Uganda Vision and the Digital Transformation Roadmap 2023/24-2027/28 championed by the Ministry of ICT and National Guidance, this document operationalizes compliance assessments across five regulatory categories. It serves as a rigorous self-audit and administrative verification tool for platforms connecting travelers with local transport, accommodation, and tour operators.

Checklist Item & Regulatory Grounding	Compliance (Y/N)	Auditor Comments & Evidence
Category 1: National ICT Policies, Laws & Regulatory Requirements		
Are electronic contracts, bookings, and customer agreements validated to ensure legal recognition under the Electronic Transactions Act, 2011 ?	[] Yes [☒] No	Technical acceptance added: unticked choice, terms version and server timestamp. Legal validation remains pending.
Are non-repudiable digital signatures integrated for high-value tour operator and B2B vendor agreements per the Electronic Signatures Act, 2011 ?	[] Yes [] No	
Does the platform maintain system-level audit logs and access controls to prevent and trace electronic fraud under the Computer Misuse Act, 2011 ?	[] Yes [] No	
Is the non-resident operating entity registered for the 5% Digital Services Tax (DST) on B2C services (Income Tax Act Sec 86A)?	[] Yes [] No	
Does the system withhold a 15% Withholding Tax (WHT) on non-resident associated/related entity digital transactions where applicable?	[] Yes [] No	
Is the platform configured to charge and quarterly remit the 18% Value Added Tax (VAT) on electronic supplies to Ugandan consumers?	[] Yes [] No	
Category 2: Cybersecurity Requirements & Recommended Measures (NISF 2026)		
Is senior leadership accountability implemented, with the Board/Accounting Officers formally owning institutional cyber risks (NISF 2026 Principle 1)?	[] Yes [] No	
Are boundary and endpoint protection standards met through enterprise-grade firewalls and Intrusion Detection/Prevention Systems (IDS/IPS) ?	[] Yes [] No	
Is a SIEM (Security Information & Event Management) tool deployed to analyze security logs across all platform components in real-time?	[] Yes [] No	

Checklist Item & Regulatory Grounding	Compliance (Y/N)	Auditor Comments & Evidence
Are regular, documented vulnerability assessments and penetration tests scheduled and conducted to proactively identify vulnerabilities?	☐ Yes ☐ No	
Is a formal Incident Response Plan documented, tested at least once a year, and linked with reporting protocols to the National CERT/CC ?	☐ Yes ☐ No	
Is infrastructure redundancy enforced for critical booking/payment databases (including redundant power UPS, dual feeds, and RAID storage)?	☐ Yes ☐ No	
Is a verified IT asset register maintained, with strict data sanitization and wiping protocols enforced prior to hardware disposal?	☐ Yes ☐ No	
Category 3: Data Protection, Privacy & Information Security Compliance (DPPA 2019)		
Is the platform formally registered as a data controller/processor with the Personal Data Protection Office (PDPO) with annual renewal?	☐ Yes ☐ No	
Is the designated Data Protection Officer (DPO) appointed, qualified, and registered with the PDPO to oversee traveler and operator data?	☐ Yes ☐ No	
Are informed consent mechanisms designed using active affirmative actions (e.g. unticked boxes), explicitly stating third-party data recipients?	☐ Yes ☐ No	
Are age-verification mechanisms and parental/guardian consent workflows active for travelers under the age of 18?	☐ Yes ☐ No	
Is there an active incident tracking protocol configured to trigger breach notifications to the PDPO within 48 hours of awareness?	☐ Yes ☐ No	
For cloud storage outside Uganda (e.g. AWS/Azure), has a Data Protection Impact Assessment (DPIA) been filed to prove equivalent protection?	☐ Yes ☐ No	
Are technical measures (including AES-256 encryption at rest, TLS 1.3 in transit, and role-based access controls) fully operational?	☐ Yes ☐ No	
Are third-party processor agreements legally structured to enforce DPPA compliance and data confidentiality on all sub-contractors?	☐ Yes ☐ No	
Category 4: Digital Service Standards, Accessibility & Interoperability (e-GIF / UGHub)		
Does the web and mobile platform comply with WCAG 2.0/2.2 AA standards (including screen-reader compatibility and contrast ratios)?	☐ Yes ☐ No	
Does the system support up to 400% text resizing and full keyboard operability for travelers with motor or visual impairments?	☐ Yes ☐ No	
Are system APIs aligned with the e-Government Interoperability Framework (e-GIF) using standardized XML or JSON data structures?	☐ Yes ☐ No	
Is the system technically integrated with the WSO2-powered UGHub platform to enable real-time federated data exchange?	☐ Yes ☐ No	
Does the integration use central API gateway controls including OAuth 2.0 authentication, rate-limiting, and centralized logging?	☐ Yes ☐ No	

Checklist Item & Regulatory Grounding	Compliance (Y/N)	Auditor Comments & Evidence
Category 5: Administrative Approvals, Registrations & Collaboration Permissions		
Has the platform's operating IT provider obtained a valid NITA-U Conformity Certificate (Level 1, 2, or 3) under the 2016 Regulations?	☐ Yes ☐ No	
Is an active MoU or SLA established with the National Identification and Registration Authority (NIRA) for real-time e-KYC NIN checks?	☐ Yes ☐ No	
Is an integration MoU established with Uganda Revenue Authority (URA) for automated TIN checks and EFRIS electronic invoicing?	☐ Yes ☐ No	
Is there a formal data-sharing SLA with the Uganda Wildlife Authority (UWA) to securely automate gorilla and park permit bookings?	☐ Yes ☐ No	
Is there a verified linkage with the Directorate of Citizenship and Immigration Control (DCIC) to check e-Visa status for international guests?	☐ Yes ☐ No	
Have the platform's legal and privacy documents been verified through NITA-U's online Regulatory Compliance Portal (compliance.nita.go.ug)?	☐ Yes ☐ No	

CATEGORY 1 - ELECTRONIC BOOKING AGREEMENTS

Technical control implemented

Checklist answer: No - legal validation is still required.

Assessment date: 24 September 2026

Implemented

- Browser booking and ticket payment paths present an unticked agreement choice.
- The choice links to the DirtTrails Terms of Service.
- The live database stores terms version 2026-09-24 and a server timestamp.
- An RPC records acceptance; direct edits to acceptance fields are blocked.

Evidence and verification

- Frontend: termsAcceptance.ts, termsVersion.ts, and BookingRepository.ts.
- Ticket flows: useOrderPaymentFlow.ts and pages/Payment.tsx.
- Database: migration 20260924120000_booking_terms_acceptance.sql.
- Production build passed; live RPC accepted a test inside a rolled-back transaction.
- An invalid terms version was rejected by the live RPC.

Remaining limits

- This records a self-attested click; it is not a digital signature or identity proof.
- Legal counsel must assess recognition under the cited Act and approve the terms text.
- Guest checkout remains restricted by the separate order access-control issue.
- Two paid bookings still require MarzPay reconciliation before integrity sign-off.